

Đề xuất Agentic AI bảo đảm an toàn khóa và nonce

Agentic AI for Key and Nonce Security Assurance and Vulnerability Hunting

Loại đề tài Môn học Mức độ Undergraduate Thời lượng 8 tuần Nền tảng Python web app

Tóm tắt đề xuất

Đề tài xây dựng một công cụ hỗ trợ phát hiện lỗi quản lý khóa và nonce trong mã nguồn Python trước khi triển khai. Hệ thống kết hợp phân tích tĩnh dựa trên cây cú pháp trừu tượng, test harness chạy trên corpus được kiểm soát và một lớp AI tùy chọn để giải thích bằng chứng. Kết luận bảo mật luôn do rule hoặc phép thử xác định tạo ra; AI không được tự xác nhận lỗ hổng, sinh khóa, thu thập bí mật hay thực hiện hành động khắc phục.

MVP tập trung vào khóa hard-code, nguồn ngẫu nhiên không phù hợp, nonce hoặc IV cố định và tái sử dụng, quản lý AEAD sai, cùng một số dấu hiệu misuse trong chữ ký số. Mã tải lên chỉ được phân tích tĩnh. Phân tích động chỉ chạy fixture do dự án quản lý trong tiến trình con bị giới hạn. Evidence được chuẩn hóa, gắn finding ID và lưu mà không giữ plaintext secret.

Proposal tuân theo lifecycle của tài liệu Course Project Guideline [1]: xác định hệ thống và biên tin cậy, lập danh mục tài sản, mô hình hóa kẻ tấn công, viết yêu cầu bảo mật và yêu cầu mật mã, chọn cơ chế, triển khai an toàn, kiểm thử đối kháng và đánh giá bằng chứng. Traceability matrix là tiêu chí trung tâm để tránh nhảy trực tiếp từ một mối đe dọa sang tên thuật toán.

Kết quả dự kiến

- Python web app có static analyzer, fixture runner, evidence store và AI adapter có thể tắt.
- Tám rule có kiểm thử dương, âm và trường hợp mơ hồ; corpus tối thiểu 60 fixture có ground truth.
- Báo cáo precision, recall, F1, tỷ lệ cảnh báo sai, hiệu năng, residual risk và coverage theo SR.

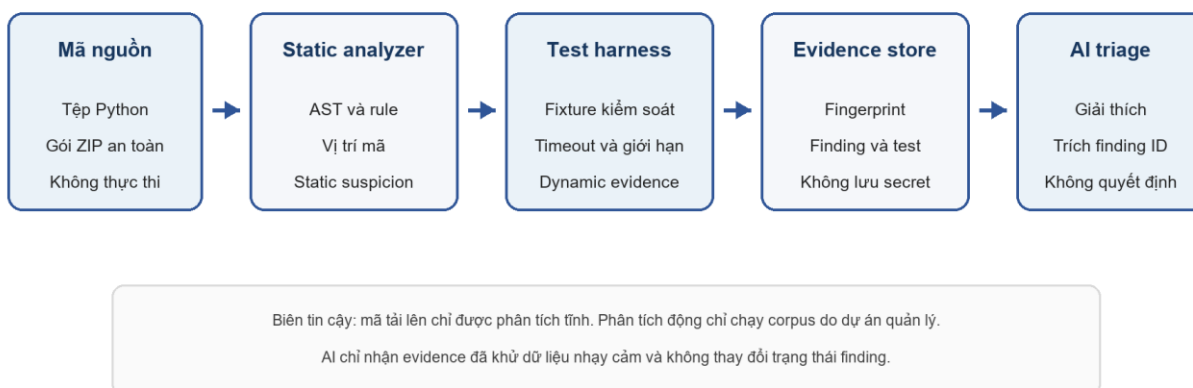
Từ khóa

Key management, nonce uniqueness, AEAD, entropy, static analysis, adversarial testing, evidence grounded AI

1 Hệ thống và phân tích biên tin cậy

Hệ thống được bảo vệ là quy trình assurance cho mã Python trong pre-production. Actors gồm người tải mã, người review AppSec, test operator và dịch vụ AI tùy chọn. Các thành phần chính là upload service, static analyzer, fixture runner, evidence store và AI adapter. Source package đi qua biên upload; AI adapter đi qua biên dịch vụ bên ngoài; subprocess fixture là biên thực thi riêng.

Kiến trúc phân tích và kiểm chứng



Hình 1 Kiến trúc dữ liệu và các biên tin cậy

Biên	Luồng qua biên	Kiểm soát đề xuất
B1 Upload	Tập py hoặc ZIP không tin cậy	Kiểm tra loại tệp, path, symlink, kích thước và số lượng
B2 Fixture	Chỉ mã trong allowlist của dự án được thực thi	Subprocess, timeout, working directory tạm và log redaction
B3 AI	Prompt rời môi trường cục bộ nếu adapter bật	Schema allowlist, bỏ literal, output validation và fallback
B4 Evidence	SQLite có thể bị đọc hoặc sửa bởi local user	Không lưu secret, digest evidence và nêu giới hạn chống sửa đổi

Giả định hệ thống

Máy pre-production và tài khoản vận hành không bị kiểm soát hoàn toàn bởi kẻ tấn công; kết nối AI dùng TLS do nhà cung cấp duy trì; source được phép kiểm tra; prototype không cung cấp multi-tenant isolation và không tạo security claim cho production.

2 Tài sản và mô hình kẻ tấn công

2 1 Danh mục tài sản

ID	Tài sản	Chủ sở hữu	Vị trí	Tác động	Bảo vệ
A1	Source tải lên	Nhóm phát triển	Thư mục tạm	IP và secret có thể bị lộ	Không thực thi, xóa sau scan
A2	Key nonce và IV quan sát	Ứng dụng mục tiêu	Memory	Lộ khóa hoặc sai correlation	Không lưu gốc, chỉ fingerprint
A3	Finding và evidence	AppSec reviewer	SQLite	Sai lệch dẫn đến false assurance	Schema, ID, digest, test link
A4	Corpus và manifest	Nhóm dự án	Repository	Sai ground truth làm sai metric	Review, hash và version
A5	Scan fingerprint key	Tool process	Memory	Mất tính riêng tư của fingerprint	Sinh theo scan và hủy
A6	AI credential và prompt	Operator	Env và transit	Lộ credential hoặc source	Không log, redaction, TLS

2 2 Năng lực kẻ tấn công

ID	Actor	Năng lực	Kịch bản ưu tiên
T1	Uploader ác ý	Kiểm soát nội dung và cấu trúc archive	ZIP slip, file bomb, parser stress
T2	Tác giả mã lỗi	Chèn literal, alias, wrapper và data flow gây nhiễu	Che giấu reuse hoặc tạo false positive
T3	Prompt injector	Đặt chỉ dẫn trong comment hoặc string	Ép AI bỏ qua evidence hay tiết lộ dữ liệu
T4	AI hoặc mạng lỗi	Trả output sai, chậm hoặc không hợp lệ	Hallucinated confirmation hoặc gián đoạn
T5	Local user	Đọc hoặc sửa SQLite và log	Lộ metadata hoặc thay evidence
T6	Operator nhầm lẫn	Đọc static suspicion như confirmed	Đưa ra kết luận vượt bằng chứng

2 3 Ưu tiên rủi ro

Ưu tiên cao gồm lộ secret qua log hoặc prompt, thực thi mã tải lên, nonce reuse không được phát hiện, tag verification bị bỏ qua và AI thay đổi kết luận. Các rủi ro này có tác động trực tiếp đến bí mật, tính toàn vẹn evidence hoặc độ tin cậy của security claim.

3 Vấn đề mục tiêu và phạm vi

3 1 Phát biểu vấn đề

Cần xây dựng một prototype phát hiện misuse key và nonce trong mã Python với độ chính xác đo được, tạo bằng chứng tái lập và duy trì hoạt động khi AI không khả dụng. Prototype phải chống đầu vào độc hại ở mức thiết kế, không thực thi upload và không lưu khóa ở dạng có thể khôi phục.

3 2 Mục tiêu

1. Xây static analyzer cho tám rule và tạo evidence có vị trí mã, rule version và nguồn giá trị.
2. Xây corpus có ground truth và test harness chỉ chạy fixture trong allowlist.
3. Xây FastAPI web app, SQLite evidence store và AI adapter chỉ diễn giải dữ liệu đã redaction.
4. Đánh giá requirement coverage, độ chính xác, hiệu năng, khả năng tái lập và AI grounding.

3 3 Câu hỏi nghiên cứu

1. AST và luồng dữ liệu nội hàm nhẹ có đạt precision từ 0.85 và recall từ 0.80 trên corpus đóng băng hay không.
2. Fixture động giảm bao nhiêu finding cần review so với static analysis đơn lẻ.
3. AI bị ràng buộc bởi evidence schema có giải thích hữu ích mà không thêm security claim ngoài bằng chứng hay không.

3 4 Phạm vi

Phân loại	Nội dung
Trong phạm vi	Python; cryptography; PyCryptodome; secrets, random và os; AST; fixture tổng hợp; pre-production
Ngoài phạm vi	Production; HSM hoặc cloud KMS thật; đa ngôn ngữ; thực thi upload; tự sửa mã; rotate key; custom crypto
Mức độ	Đạt baseline undergraduate; phân tích side channel, liên thủ tục sâu và quantum risk là hướng mở rộng

4 Yêu cầu bảo mật và yêu cầu mật mã

4 1 Yêu cầu bảo mật hệ thống

ID	Yêu cầu có thể kiểm thử	Tiêu chí xác minh
SR01	Không thực thi mã tải lên và phải từ chối archive thoát biên hoặc vượt giới hạn.	Adversarial upload tests
SR02	Không lưu hoặc gửi plaintext key, nonce nhạy cảm, credential hay source literal sang AI.	Privacy and prompt inspection
SR03	Mỗi finding phải truy ngược được tới rule, vị trí mã, version và test evidence.	Schema and linkage tests
SR04	AI không được thay severity, trạng thái, rule result hoặc test result.	Prompt injection and schema tests
SR05	Static scan và rule explanation phải hoạt động khi AI bị tắt hoặc lỗi.	Failure injection
SR06	Tool phải nhận diện các misuse nonce, RNG, AEAD, signature và lifecycle đã chọn.	Ground truth corpus
SR07	Dynamic confirmed chỉ được đặt khi fixture cho kết quả tái lập đúng oracle.	Three run reproducibility

4 2 Yêu cầu mật mã và cơ chế

ID	Thuộc tính	Cơ chế và tham số	Ràng buộc triển khai
CR01	Fingerprint không đảo ngược và tách miền	HMAC SHA 256 với scan key 256 bit	Key literal, nonce và source dùng domain label khác
CR02	Sinh key và nonce từ CSPRNG	secrets token bytes hoặc API generate key	Không dùng random cho mục đích mật mã
CR03	Nonce duy nhất theo từng key trong fixture AEAD	AES GCM nonce 96 bit hoặc counter policy	Theo dõi fingerprint key nonce
CR04	AEAD fail closed khi tag sai	AESGCM decrypt hoặc decrypt and verify	InvalidTag hoặc ValueError kết thúc xử lý
CR05	Key separation và lifetime rõ	Scan key riêng; fixture key riêng từng case	Không dùng AI credential làm data key

4 3 Lý do lựa chọn

HMAC được chọn thay cho SHA 256 không khóa để giảm khả năng đoán các literal phổ biến từ fingerprint. Mã hóa reversible không cần thiết vì hệ thống không có nhu cầu khôi phục giá trị gốc. API AEAD mức cao được ưu tiên để tránh tự ghép encryption và authentication. Các lựa chọn này truy về CR thay vì dựa vào độ phổ biến của thuật toán [2] [3] [4].

5 Phương pháp và kiến trúc bảo đảm

5 1 Phương pháp nghiên cứu

Đề tài áp dụng design science kết hợp thực nghiệm. Mỗi threat được ánh xạ sang SR và CR; mỗi rule được định nghĩa bằng trigger, evidence, severity, trạng thái ban đầu, positive fixture, negative fixture và trường hợp mơ hồ. Corpus được đóng băng trước khi đo kết quả cuối để hạn chế tuning theo test set.

5 2 Luồng bằng chứng

Luồng bằng chứng và trạng thái phát hiện



Hình 2 Luồng trạng thái finding

1. Upload service tạo scan ID, kiểm tra cấu trúc và đặt source trong thư mục tạm.
2. Static analyzer phát hiện pattern, chuẩn hóa location và tạo Static suspicion hoặc Needs review.
3. Fingerprint service dùng scan key trong memory để tương quan key và nonce mà không lưu giá trị gốc.
4. Fixture runner chạy test được allowlist; chỉ oracle tái lập được mới tạo Dynamically confirmed.
5. AI adapter nhận evidence đã redaction và tạo phần giải thích tách khỏi kết luận xác định.

5 3 Key lifecycle của prototype

Vật liệu	Sinh	Lưu	Kết thúc vòng đời
Scan key	secrets token bytes 32	Memory của scan	Hủy khi scan kết thúc hoặc lỗi
Fixture key	API generate key của thư viện	Subprocess fixture	Hủy khi process kết thúc
Nonce state	Random 96 bit hoặc counter theo fixture	Trong fixture	Không dùng lại với cùng key
AI credential	Cấu hình ngoài source	Environment	Không log; operator rotate

5 4 Giới hạn entropy testing

Phép thử thống kê chỉ dùng để phát hiện lỗi rõ như seed cố định, chuỗi lặp và collision bất thường trong fixture. Kết quả vượt qua test không chứng minh một nguồn là CSPRNG và không thay thế đánh giá entropy theo NIST SP 800-90B [6].

6 Danh mục phát hiện và evidence schema

Rule	Lớp lỗi	Dấu hiệu	Mức	Trạng thái
KN001	Hard coded key	Literal truyền vào API key	High	Static suspicion
KN002	Insecure RNG	random hoặc seed cố định tạo key nonce token	High	Static suspicion
KN003	Fixed nonce or IV	Literal hoặc hằng số dùng trong encrypt	Critical	Static suspicion
KN004	Nonce reuse	Cùng fingerprint key nonce trong nhiều encrypt	Critical	Dynamic confirmed
KN005	AEAD tag bypass	Bỏ verify hoặc tiếp tục sau InvalidTag	Critical	Static suspicion
KN006	Unsafe lifecycle	Key dùng nhiều mục đích hoặc thiếu lifetime metadata	Medium	Needs review
KN007	Signature nonce	ECDSA hoặc DSA dùng k cố định lặp hoặc RNG yếu	Critical	Static or dynamic
KN008	Nonce policy	Độ dài không phù hợp wrapper hoặc policy	Medium	Static suspicion

6 1 Evidence schema

Trường	Nội dung	Bắt buộc
finding_id	ID bất biến	Có
rule_id rule_version	Nguồn logic tạo finding	Có
location	Path tương đối dòng và cột	Có
evidence	AST node API source kind và điều kiện	Có
fingerprints	HMAC đã tách miền không chứa giá trị gốc	Khi cần
test_run_id	Fixture oracle environment và log đã redaction	Nếu có
ai_explanation	Giải thích có finding ID tách khỏi rule result	Tùy chọn

6 2 Quy tắc trạng thái

Trạng thái	Ý nghĩa	Thành phần được đặt
Static suspicion	Rule có dấu hiệu nhưng chưa đủ ngữ cảnh	Rule engine
Dynamically confirmed	Fixture allowlist tái lập đúng oracle	Test harness
Needs review	Không xác định an toàn nguồn hoặc ngữ cảnh	Reviewer

7 Thiết kế triển khai an toàn

7 1 Giao diện hệ thống

Method	Endpoint	Chức năng	Kết quả
POST	/api/v1/scans	Tạo scan từ py hoặc ZIP hợp lệ	scan_id
GET	/api/v1/scans/{scan_id}	Xem trạng thái và finding	scan summary
GET	/api/v1/findings/{finding_id}	Xem evidence	finding object
POST	/api/v1/fixtures/runs	Chạy fixture set trong allowlist	test_run_id
POST	/api/v1/findings/{id}/explain	Yêu cầu AI giải thích	explanation hoặc fallback

7 2 Hợp đồng finding

```
{
  "finding_id": "F-2026-0001", "rule_id": "KN003",
  "status": "static_suspicion", "severity": "critical",
  "location": {"path": "src/crypto.py", "line": 18},
  "evidence": {"api": "AESGCM.encrypt", "source": "constant"},
  "recommendation": "Tạo nonce duy nhất theo từng key"
}
```

7 3 Kiểm soát triển khai

Bề mặt	Kiểm soát
Upload	Tối đa 5 MB, 200 tệp, không archive lồng, không absolute path hoặc symlink
Parser	Giới hạn thời gian và số node; lỗi cú pháp trả finding parse error an toàn
Fixture	Subprocess, timeout 5 giây, working directory tạm, environment allowlist
Storage	SQLite chỉ lưu metadata; source và scan key không persist; parameterized query
AI	Prompt schema allowlist, bỏ comment và literal, response schema validation
Logging	Không log source, key, nonce, credential hoặc prompt đầy đủ

7 4 Công nghệ

FastAPI và Jinja2 cung cấp web UI không dùng SPA; Python ast làm nền cho rule engine; pytest quản lý fixture; SQLite lưu evidence metadata. cryptography và PyCryptodome chỉ được dùng qua API tiêu chuẩn. Không viết primitive mật mã mới.

8 Kiểm thử đối kháng và đánh giá

8 1 Corpus và thiết kế test

Corpus gồm tối thiểu 60 fixture: 30 mẫu lỗi, 20 mẫu an toàn và 10 mẫu mơ hồ. Mỗi fixture có manifest ghi threat, SR, CR, rule kỳ vọng, trạng thái, oracle và nguồn tham chiếu. Mẫu gần trùng được nhóm trước khi chia tuning và test để tránh rò rỉ cấu trúc.

ID	Loại	Kịch bản	Kết quả mong đợi
TS01	Positive	Key và nonce hợp lệ, encrypt decrypt và sign verify bình thường	Không có finding sai
TS02	Negative	Sửa ciphertext, tag, AAD, key hoặc signature	Giải mã hoặc verify bị từ chối
TS03	Adversarial	Reuse nonce, seed cố định, hard-coded key	Rule đúng và evidence đủ
TS04	Upload	ZIP slip, symlink, nested archive, file bomb	Từ chối trước phân tích
TS05	AI	Prompt injection, timeout, malformed response	Finding bất biến và fallback
TS06	Privacy	Canary secret trong source và fixture	Không xuất hiện trong DB log prompt
TS07	Reproducibility	Chạy cùng fixture ba lần	Kết quả giống nhau

8 2 Chỉ số đánh giá

Nhóm	Cách đo	Ngưỡng MVP
Detection	Precision recall F1 và FPR theo rule	Precision từ 0.85; recall từ 0.80
Performance	P50 P95 và peak memory cho 10 50 100 tệp	P95 dưới 5 giây cho 100 tệp
Reproducibility	Tỷ lệ fixture cho cùng kết quả qua ba lần	100 phần trăm
AI grounding	Finding ID coverage và unsupported security claim	100 phần trăm ID; 0 claim ngoài evidence
Privacy	Canary secret xuất hiện trong DB log prompt	0 lần
Coverage	SR verified partially verified not verified	Báo cáo mọi SR

8 3 Cách diễn giải

Precision, recall và F1 được báo cáo kèm số mẫu và confidence interval bootstrap nếu đủ dữ liệu. Benchmark phải công bố máy, phiên bản Python và thư viện. Một test pass chỉ hỗ trợ requirement đã ánh xạ; không được dùng để tuyên bố toàn hệ thống an toàn.

9 Ma trận truy vết bắt buộc

Ma trận duy trì chuỗi Threat đến Security Requirement đến Cryptographic Requirement đến Mechanism đến Implementation Control đến Security Test đến Evidence. Evidence ở proposal là kết quả mong đợi; báo cáo cuối phải thay bằng kết quả quan sát và trạng thái verified, partially verified hoặc not verified.

Threat	SR	CR	Mechanism	Implementation control	Security test	Evidence expected
T1 Source hoặc secret bị lộ	SR02	CR01 CR02 CR05	HMAC SHA 256 và scan key	Redaction không persist source	TS06 canary secret	Không có secret trong DB log prompt
T1 Archive thoát biên hoặc DoS	SR01	Không áp dụng	Structural validation	Path size count allowlist	TS04 crafted ZIP	Upload bị từ chối trước parser
T3 Prompt injection hoặc T4 AI sai	SR04 SR05	Không áp dụng	Schema allowlist và fallback	AI output tách khỏi finding	TS05 injection failure	Status severity và result bất biến
T2 Nonce reuse bị che giấu	SR03 SR06 SR07	CR01 CR03	HMAC correlation và 96 bit policy	KN003 KN004 và fixture oracle	TS03 reuse nonce	Finding liên kết rule và test run
T2 RNG yếu hoặc key hard code	SR03 SR06	CR02 CR05	CSPRNG và key separation	KN001 KN002 KN006	TS03 weak RNG hard code	Finding đúng location và source kind
T2 Bỏ kiểm tra AEAD tag	SR06 SR07	CR04	High level AEAD verify	KN005 và fail closed fixture	TS02 sửa tag AAD key	Decrypt từ chối và evidence tái lập
T6 Nhầm suspicion thành confirmed	SR03 SR04 SR07	Không áp dụng	State machine xác định	Chỉ harness đặt confirmed	TS05 và TS07	Provenance và status transition đúng

9 1 Quy tắc cập nhật evidence

- Kết quả cuối phải ghi expected và observed riêng, kèm test run ID và môi trường.
- Requirement không có test hoặc test chưa chạy phải được ghi Not verified, không suy diễn từ code review.
- Residual risk phải chỉ ra assumption chưa kiểm thử, giới hạn corpus và quyền của local user.

10 Kế hoạch nguồn lực và sản phẩm

Tuần	Công việc	Evidence đầu ra
1	System trust assets threat model	System model asset inventory threat backlog
2	SR CR traceability và corpus	Requirement set manifest fixture mẫu
3	AST analyzer KN001 đến KN004	Rule engine và unit tests
4	Rule KN005 đến KN008	Rule catalog và negative tests
5	Harness fingerprint evidence store	Fixture runner SQLite privacy tests
6	FastAPI Jinja2 và upload controls	End to end scan workflow
7	AI adapter và thực nghiệm	Grounding tests metrics trace matrix
8	Ổn định demo và báo cáo	Release runbook results residual risks

10 1 Sản phẩm bàn giao

Artifact guideline	Sản phẩm của đề tài
A1 A2 A3	System model asset inventory threat model
A4 A5 A6 A7	SR CR security architecture mechanism table và key lifecycle
A8	Python web app configuration và hướng dẫn chạy tái lập
A9	Positive negative adversarial tests và test evidence
A10	Metrics traceability matrix residual risks và scoped conclusion

10 2 Rủi ro thực hiện

Rủi ro	Xử lý
False positive cao	Rule có điều kiện, safe fixture và Needs review
AI suy diễn	Schema hẹp, citation check và deterministic fallback
Lộ secret	Canary test, redaction, HMAC fingerprint, không lưu source
Phạm vi vượt 8 tuần	Giữ Python only, tám rule và không xây auth multi tenant
Corpus thiên lệch	Positive negative ambiguous samples và báo cáo theo rule

10 3 Nguồn lực

Nhóm một hoặc hai thành viên, máy cá nhân phổ thông, Python 3.12 hoặc mới hơn, Git và môi trường ảo. API AI có giới hạn chi phí và là tùy chọn; core không phụ thuộc API key.

11 Giới hạn đạo đức và kết luận

11 1 Giới hạn và residual risk

- AST nội hàm có thể bỏ sót reflection, wrapper phức tạp và luồng liên thủ tục; finding âm không chứng minh mã an toàn.
- Entropy test không chứng nhận CSPRNG; key lifecycle rule chỉ đánh giá metadata quan sát được.
- SQLite digest không chống được local attacker có toàn quyền; multi-tenant integrity nằm ngoài MVP.
- Dynamically confirmed chỉ áp dụng cho fixture; không phải bằng chứng production đang bị khai thác.
- Prototype chỉ dùng trên source được phép, không tự khai thác, sửa mã, rotate key hoặc gửi secret ra ngoài.

11 2 Kết luận có giới hạn

Dưới threat model và assumptions đã nêu, nếu TS01 đến TS07 đạt ngưỡng và traceability matrix không còn requirement quan trọng ở trạng thái Not verified, evidence sẽ hỗ trợ kết luận rằng prototype phát hiện được các misuse đã chọn trong corpus pre-production. Kết luận không mở rộng sang mọi lỗi mật mã, mọi ngôn ngữ hoặc hệ thống production.

12 Tài liệu tham khảo

- [1] Cryptography and Applications Course Project Guideline, tài liệu môn học do giảng viên cung cấp, 2026.
- [2] NIST, Recommendation for Block Cipher Modes of Operation GCM and GMAC, SP 800-38D, 2007. [Nguồn](#)
- [3] D. McGrew, An Interface and Algorithms for Authenticated Encryption, RFC 5116, 2008. [Nguồn](#)
- [4] E. Barker, Recommendation for Key Management Part 1 General, NIST SP 800-57 Part 1 Rev 5, 2020. [Nguồn](#)
- [5] E. Barker and J. Kelsey, Random Number Generation Using DRBGs, NIST SP 800-90A Rev 1, 2015. [Nguồn](#)
- [6] M. Sonmez Turan et al, Entropy Sources Used for Random Bit Generation, NIST SP 800-90B, 2018. [Nguồn](#)
- [7] E. Barker et al, Recommendation for Cryptographic Key Generation, NIST SP 800-133 Rev 2, 2020. [Nguồn](#)
- [8] T. Pornin, Deterministic Usage of DSA and ECDSA, RFC 6979, 2013. [Nguồn](#)
- [9] Python Software Foundation, secrets Generate secure random numbers for managing secrets. [Nguồn](#)
- [10] The cryptography developers, Authenticated encryption API documentation. [Nguồn](#)
- [11] PyCryptodome, Modern modes of operation for symmetric block ciphers. [Nguồn](#)